

GSG-04

90-Day Security Roadmap

Phased Action Plan for SMB Security Improvement

A practical, 30-day-milestone roadmap for moving from baseline security awareness to measurable improvement. Designed for small businesses with limited IT resources and no dedicated security team.

Days 1-30

Foundation

Days 31-60

Build

Days 61-90

Sustain

// HOW TO USE THIS ROADMAP

This roadmap organizes your security improvement work into three 30-day phases. Each phase builds on the last — foundation controls in Phase 1 enable more advanced controls in Phases 2 and 3. Assign an owner to each action and track completion using the checkbox column.

You do not need to complete every action to see meaningful improvement. Work through the list in order — Phase 1 actions provide the highest return on investment and address the most common causes of small business incidents.

How to Prioritize: If you have completed the Green Security Group Security Assessment, use your lowest-scoring domains to identify which actions to prioritize within each phase. Address Critical Gaps (score 0) before Improvement Areas (score 1).

PHASE 1 Foundation

Days 1-30

Phase 1 focuses on the highest-impact, lowest-complexity controls. These actions address the most common causes of small business security incidents and should be completed before moving to Phase 2.

#	Action	Owner	Done
1	Enable multi-factor authentication on all email accounts (Microsoft 365 or Google Workspace)	IT / Owner	☐
2	Enable MFA on all cloud services — file storage, CRM, accounting, and any other business platforms	IT / Owner	☐
3	Deploy a business password manager (e.g. Bitwarden Teams) and onboard all staff	IT / Owner	☐
4	Audit all user accounts — eliminate shared accounts and remove former employee access	IT / Owner	☐
5	Verify automatic OS updates are enabled on all workstations and servers	IT / Owner	☐
6	Confirm business-grade antivirus or EDR is installed and active on all endpoints	IT / Owner	☐
7	Change default admin credentials on all network devices (routers, switches, access points)	IT / Owner	☐
8	Separate guest Wi-Fi from the business network — configure a dedicated guest SSID	IT / Owner	☐
9	Verify current offsite or cloud backups are in place and test a restoration	IT / Owner	☐
10	Distribute and acknowledge the Acceptable Use Policy with all staff (GSG-03)	Manager	☐

PHASE 2 Build

Days 31-60

Phase 2 formalizes the controls established in Phase 1 and addresses the process and documentation gaps most likely to cause problems during an audit, incident, or regulatory review.

#	Action	Owner	Done
1	Document and distribute the Password Policy — collect signed acknowledgments from all staff (GSG-03)	Owner	☐
2	Conduct a data mapping exercise — document what sensitive data you hold and where it lives	Owner / IT	☐
3	Verify encryption is enabled at rest: BitLocker on Windows, FileVault on Mac for all laptops	IT	☐
4	Verify all public-facing web services use HTTPS with valid TLS certificates	IT	☐

5	Build a vendor inventory — list all third parties with system or data access	Manager / IT	☐
6	Review and disable any unused remote access, VPN accounts, or open firewall rules	IT	☐
7	Create or update the employee onboarding/offboarding security checklist	HR / Manager	☐
8	Run a basic phishing awareness session with all staff	Manager / IT	☐
9	Conduct a tabletop exercise using the Incident Response Plan (GSG-03)	Manager / IT	☐
10	Review and complete the GSG-02 Risk Assessment Checklist — document your current scores	IT / Owner	☐
11	Obtain cyber liability insurance quotes from at least two providers	Owner	☐

PHASE 3 **Sustain**

Days 61-90

Phase 3 focuses on building the ongoing processes and monitoring capabilities that will keep your security posture strong beyond the initial 90-day period.

#	Action	Owner	Done
1	Schedule annual repeats of all Phase 1 and Phase 2 actions in your business calendar	Owner	☐
2	Run a phishing simulation using a free tool (KnowBe4 Free, Gophish, or equivalent)	IT / Manager	☐
3	Complete a patch audit — verify all OS, application, and network device patches are current	IT	☐
4	Review vendor contracts — identify which are missing security addendums for renewal	Manager	☐
5	Implement or review your data retention and disposal policy	Manager / IT	☐
6	Establish network monitoring or log review process — set a monthly calendar reminder	IT	☐
7	Schedule quarterly access reviews — validate all accounts align with current roles	Manager / IT	☐
8	Add security awareness training to all new employee onboarding checklists	HR / Manager	☐
9	Brief leadership on your current security posture using the Risk Assessment Checklist results	IT / Owner	☐
10	Repeat the GSG Security Assessment in 6-12 months to measure improvement	IT / Owner	☐

// ONGOING COMMITMENTS

The following activities should be recurring after you complete the 90-day roadmap:

Frequency	Activity
Monthly	Review network and access logs for anomalies. Check for outstanding patches.
Quarterly	Test backup restoration. Review active vendor access. Rotate credentials for privileged accounts.
Annually	Repeat the Security Assessment. Update policies. Run a phishing simulation and tabletop exercise. Review cyber insurance coverage.
On hire	Complete security onboarding checklist. Provision accounts under least privilege. Acknowledge all policies.

On departure

Disable accounts immediately. Revoke all access — cloud, VPN, physical. Recover devices.

// AI DISCLOSURE

Developed with assistance from Claude (Anthropic). Reviewed and validated by Paul Green, CISSP.